

Security Protocols

Module 4, Part 1/2: Foundations, Authentication and IP Security

CSC 3114: Cryptology and Coding Theory

Denish Azamuke, PhD

Office: CoCIS, Block B, Level 3

October 5, 2026

Part 1: This lecture

- Security protocol foundations.
- Security facilities in the TCP/IP stack.
- One-way and mutual authentication.
- Replay attacks and freshness.
- IP security: AH, ESP, modes and IKE.

Part 2: Next lecture

- SSL background and TLS.
- TLS authentication and secure sessions.
- Email security.
- Comparing protection at different layers.

Learning Outcomes

By the end of this lecture, you should be able to:

- 1 Distinguish a cryptographic primitive from a security protocol.
- 2 Explain one-way and mutual entity authentication.
- 3 Trace a challenge–response exchange and explain replay resistance.
- 4 Locate security mechanisms in the TCP/IP stack.
- 5 Compare AH and ESP, and transport and tunnel modes.
- 6 Explain the roles of security associations and IKE in IPsec.

Cryptographic Primitives and Security Protocols

A primitive performs a basic operation.

- Encryption conceals plaintext.
- A MAC authenticates data using a shared key.
- A signature supports public verification.
- Diffie–Hellman establishes shared keying material.

A protocol defines an interaction.

- Who sends each message?
- What does each message contain?
- Which keys and checks are required?
- When is the exchange accepted or rejected?

Note

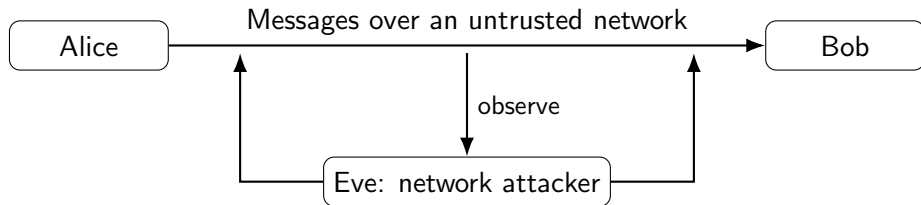
A security protocol combines cryptographic operations with message ordering and verification rules to achieve a security goal.

Security Goals

Goal	Question the protocol should address
Confidentiality	Can an unauthorized party read the protected data?
Integrity	Can a receiver detect unauthorized changes?
Entity authentication	Is the claimed peer participating in this exchange?
Data-origin authentication	Did this message come from a holder of the expected key?
Freshness	Does this evidence belong to the current exchange?
Availability	Can legitimate participants use the service?

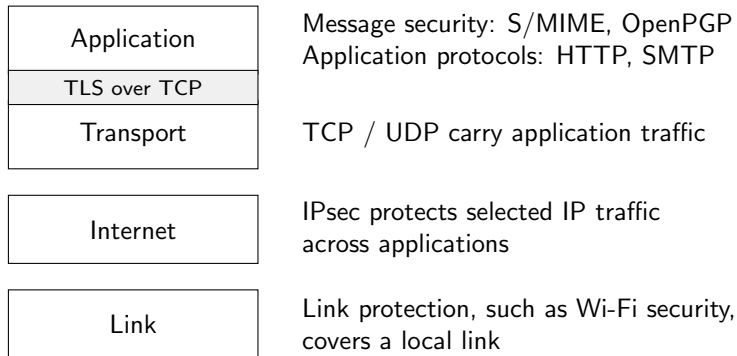
Encryption alone does not establish all these properties. Cryptography also cannot prevent every denial-of-service attack.

The Network Threat Model



- A passive attacker observes traffic.
- An active attacker may alter, inject, replay, delay or drop messages.
- For our examples, uncompromised endpoints protect their secret keys.

Security Facilities in the TCP/IP Stack



Authentication, Authorisation and Accounting

Authentication Verifies a claimed identity or control of its credential.

Authorisation Determines which operations that identity may perform.

Accounting Records relevant actions for auditing and accountability.

University portal

A student signs in successfully. The portal allows the student to view their own results, denies access to another student's results, and records the access.

Discussion: Which part of this example is authentication, and which is authorisation?

Authentication Factors and Credentials

- **Something you know:** a password or PIN.
- **Something you have:** a security key or a device holding a private key.
- **Something you are:** a biometric characteristic.

Multi-factor authentication

Multi-factor authentication combines evidence from different factor categories. Two passwords still belong to the same category.

- Network peers may authenticate with pre-shared keys or certificates.
- A certificate binds a name to a public key under a trust model.
- The peer must also prove control of the corresponding private key.

One-Way and Mutual Authentication

	One-way	Mutual
Who verifies whom?	One party verifies the other.	Each party verifies the other.
Example	Browser verifies server in TLS.	Both peers verify credentials.
What remains?	Reverse direction needs a separate proof.	Authorisation needs separate checks.

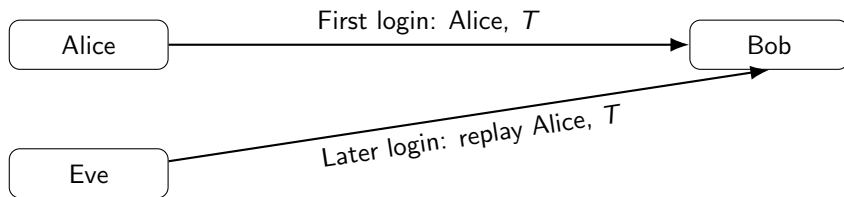
Meaning of one-way

One-way describes the direction of authentication. The protocol can still send several messages in both directions.

A Fixed Authentication Token Can Fail

Suppose Alice proves her identity by sending the same token every time:

$$T = \text{MAC}_K(\text{Alice}).$$



Replay attack

Eve can reuse the captured token without knowing K . A valid MAC does not, by itself, show that Alice is participating now.

Freshness: Nonces, Timestamps and Counters

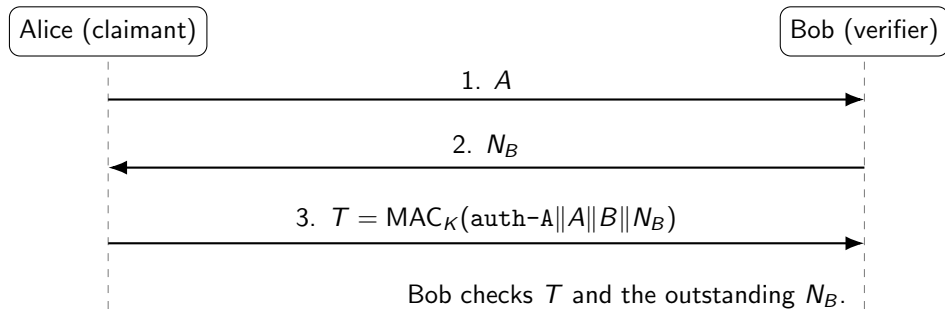
Method	Idea	Required check
Nonce	A value used once in an exchange.	Match it to an outstanding challenge and prevent reuse.
Timestamp	Authenticate the time with the message.	Check clock tolerance and handle duplicates within the time window.
Counter	Authenticate an increasing sequence number.	Track accepted values and reject replays.

Notation for Protocol Exchanges

A, B	Alice and Bob, including their protocol identities.
K	A high-entropy secret key shared by Alice and Bob.
N_A, N_B	Fresh nonces generated by Alice and Bob.
$X \parallel Y$	Concatenation with unambiguous field encoding.
$\text{MAC}_K(M)$	A message authentication code on message M .
$\text{Sign}_{sk_A}(M)$	A signature on M using Alice's private key.
$A \rightarrow B : M$	Alice sends message M to Bob.

Assumption: Each verifier associates the expected identity with the correct key. A claimed name alone is insufficient.

One-Way Challenge–Response

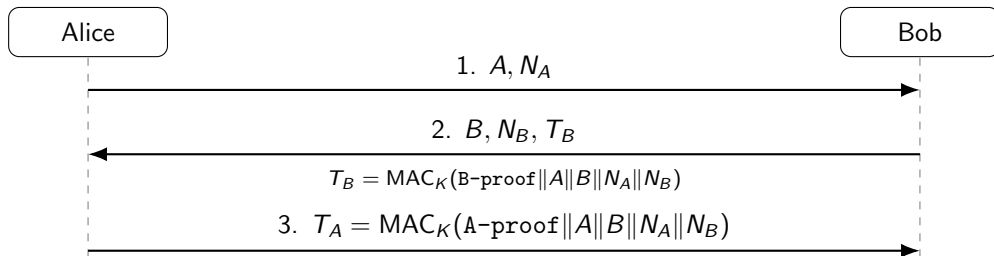


What Bob learns

A party holding the expected key produced a response to Bob's current challenge. This exchange does not authenticate Bob to Alice.

Mutual Challenge–Response

Example Alice and Bob share K and use distinct role labels.



Alice verifies T_B before replying. Bob verifies T_A before accepting.

Protocol binding

Each proof binds both identities, both nonces and the sender's role to this exchange.

Reflection and Role Separation

A dangerous design

- Both roles answer a nonce with the identical formula $\text{MAC}_K(N)$.
- An attacker may open another session and ask the target to answer its own challenge.
- The attacker reflects that answer into the original session.

Design defences

- Use distinct role labels or directional keys.
- Bind identities and the exchange context into each proof.
- Enforce message order and session state.
- Use established, analysed protocols.

Note

A proof valid in one role or session should not become a valid proof in a different role or session.

Authentication Using Digital Signatures

Alice can answer Bob's challenge with

$$\sigma = \text{Sign}_{sk_A}(\text{auth-A} \| A \| B \| N_B \| \text{context}).$$

Bob then checks:

- 1 The trusted binding between Alice's identity and public key.
- 2 The signature using Alice's public key.
- 3 The expected identities, context and outstanding challenge.

Certificate versus proof

A certificate supplies a signed identity–key binding. A fresh signature provides evidence that the peer controls the corresponding private key.

A certificate-based protocol also needs certificate-path, validity and applicable status checks.

Authentication and Session Key Establishment

- Authentication checks the peer's identity or credential possession.
- Key establishment gives peers shared keying material for a session.
- An **authenticated key exchange** binds these two operations together.

Unauthenticated Diffie–Hellman

An active attacker can substitute public values and establish separate keys with Alice and Bob. Both endpoints may obtain a secret key without obtaining the intended peer's identity.

Protocol requirement

Authenticate the exchange transcript, including the key-exchange values and identities, so that the session key is associated with the intended peer.

IP Security: Purpose and Scope

IPsec is a suite of mechanisms for protecting selected traffic at the IP layer.

- Policies identify traffic that needs protection.
- Peers agree on security parameters and keys.
- Packet protection applies across the selected IPsec path.

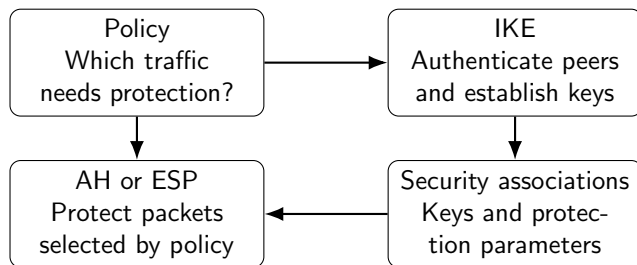
University network example

Two campus gateways protect traffic between campus networks over a public network. The gateways are the IPsec endpoints, even though the application hosts are behind them.

Protection boundary

IPsec protection ends at the IPsec endpoint. A gateway-to-gateway tunnel does not automatically protect traffic inside either campus network.

IPsec Components



AH: Authentication Header.

ESP: Encapsulating Security Payload.

AH and ESP

Property	AH	ESP
Confidentiality	No encryption.	Available when encryption is selected.
Integrity and origin authentication	Yes.	Available with integrity protection or authenticated encryption.
IP header coverage	Protects immutable or predictable IP header fields.	Does not protect the outer IP header.
Replay defence	Sequence numbers and receiver replay checks.	Sequence numbers and receiver replay checks with integrity.
NAT interaction	Address rewriting conflicts with AH authentication.	NAT traversal can encapsulate ESP in UDP.

For our ESP examples, assume encryption, integrity protection, and anti-replay checks are enabled.

Transport Mode and Tunnel Mode

Transport mode

- Protects the upper-layer payload of an IP packet.
- Retains the original IP header for routing.
- Example: two IPsec-capable hosts communicate directly.

Tunnel mode

- Encapsulates the entire original IP packet.
- Adds a new outer IP header.
- Suitable for gateway tunnels and remote access.

Two independent choices

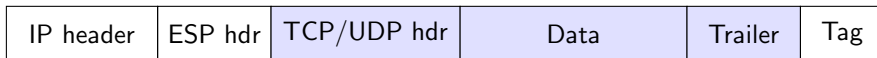
AH versus ESP selects the packet-protection protocol. Transport versus tunnel selects how that protection is applied to the packet.

ESP Transport Mode: Packet Layout

Original packet



After ESP transport protection

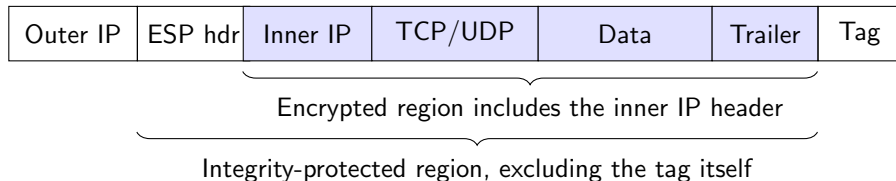


Encrypted region

Integrity-protected region, excluding the tag itself

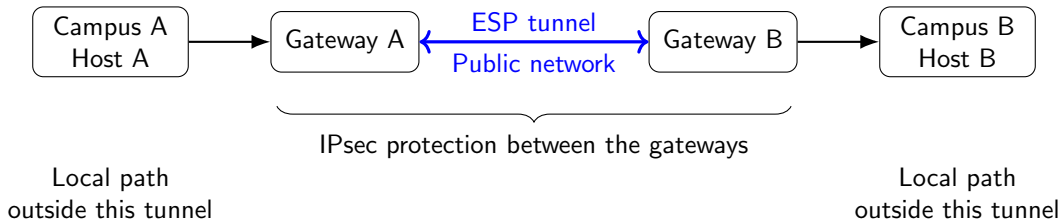
ESP Tunnel Mode: Packet Layout

The original IP packet becomes the tunnel payload.



- Outer addresses identify the tunnel endpoints.
- Inner addresses identify the original communicating hosts.
- Observers can still see outer addresses and traffic timing/size.

Site-to-Site VPN: Protection Boundaries



Address interpretation

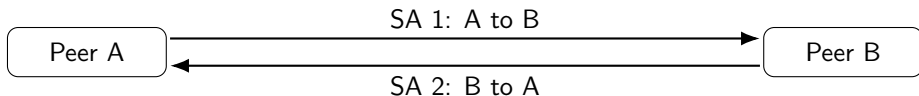
Inner packet: Host A to Host B. Outer packet: Gateway A to Gateway B.

End-to-end application protection may still be needed beyond the gateways.

Security Associations

A **security association (SA)** records the parameters for protecting traffic in one direction with AH or ESP.

- Packet-protection protocol and mode.
- Algorithms and traffic keys.
- Security Parameters Index (SPI).
- Sequence-number and replay state.
- Lifetime and renewal information.



Bidirectional communication normally uses a pair of IPsec SAs.

IPsec Traffic Policy

- The **Security Policy Database (SPD)** decides how traffic is handled.
- The **Security Association Database (SAD)** holds active SA parameters.

Action	Meaning
Protect	Apply IPsec using a suitable SA, establishing one if required.
Bypass	Permit traffic without IPsec protection.
Discard	Drop the traffic.

Example: Protect traffic between two campus subnets and discard traffic explicitly prohibited by policy.

Replay Protection with Sequence Numbers

Assume a window of size $W = 8$ and highest authenticated sequence number $H = 105$.

$$\text{Current window} = [H - W + 1, H] = [98, 105].$$

Receiver tracks which numbers in this window have been accepted.

98	99	100	101	102	103	104	105
----	----	-----	-----	-----	-----	-----	-----

- 100, already accepted: reject as a duplicate.
- 102, not yet accepted: eligible if integrity verification succeeds.
- 97: reject as too old.
- 108, with valid integrity: accept and advance the window to $[101, 108]$.

IKEv2: Establishing IPsec Protection

Internet Key Exchange version 2 (IKEv2) establishes and manages keying state for IPsec.

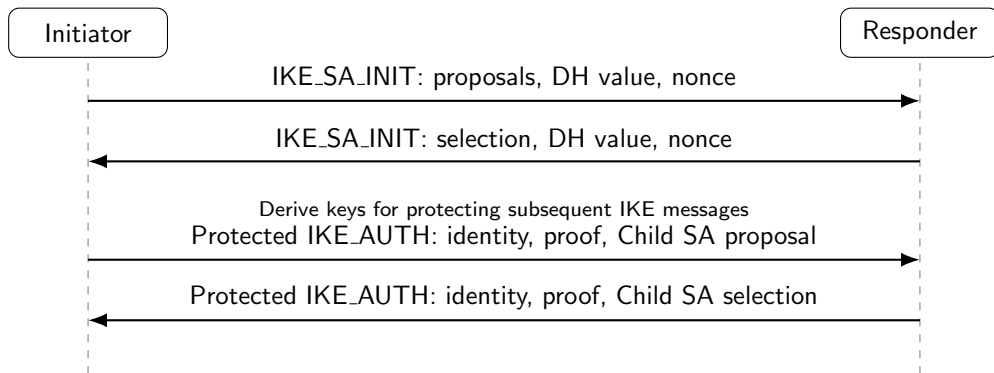
- 1 Negotiate algorithms and exchange nonces and Diffie–Hellman values.
- 2 Authenticate peers and bind their identities to the exchange.
- 3 Establish an IKE SA and an initial Child SA pair for IPsec traffic.
- 4 Renew keys and manage additional Child SAs when needed.

Two roles

IKE negotiates and authenticates the setup. AH or ESP then processes the protected data packets.

An IKE SA protects IKE control messages. A Child SA pair protects selected IP traffic in both directions.

IKEv2: Simplified Initial Exchange



The peers authenticate the exchange during IKE_AUTH. IPsec data protection follows successful setup. Details and optional messages are omitted.

Design Example: Connecting Two Campuses

Requirement: Protect IP traffic between the campus networks over a public network.

- 1 Choose the two gateways as the tunnel endpoints.
- 2 Configure ESP in tunnel mode with authenticated encryption.
- 3 Use IKEv2 with an appropriate peer-authentication method.
- 4 Define traffic policies for the authorised campus subnets.
- 5 Maintain separate directional SAs and enable replay checks.

What this design does not establish

The tunnel authenticates the gateways. Applications still need user authentication, authorisation and appropriate protection on paths beyond those gateways.

Exercise

- ① Describe a one-way protocol in which a server authenticates a client using a shared key and a fresh challenge.
- ② Explain why an encrypted but fixed login token may still be replayed.
- ③ Select an IPsec mode for a gateway-to-gateway VPN. State which IP header ESP conceals when encryption is enabled.
- ④ An anti-replay window has $W = 8$ and $H = 42$. Classify incoming sequence numbers 34, 39 and 45. Assume 39 was already accepted and 45 has valid integrity.

Solution

- ① Server sends fresh N_S . Client returns a MAC over the nonce, identities, and role label. Server checks the expected tag and consumes the challenge.
- ② Encryption can hide the token while an attacker records and resends the unchanged ciphertext. The verifier still needs a freshness check.
- ③ Tunnel mode. With ESP encryption, the original inner IP header is concealed. The new outer header remains visible for routing.
- ④ The initial window is [35, 42]:
 - 34: too old, so reject.
 - 39: already accepted, so reject as a replay.
 - 45: accept after integrity verification and move to [38, 45].

Questions?